

网络安全基础知识点汇总

一、网络安全概述

1.1 定义

信息安全:为数据处理系统建立和采用的技术和管理的安全保护，保护计算机硬件、软件和数据不因偶然和恶意的原因遭到破坏、更改和泄露。

网络安全:

- 防止未授权的用户访问信息
- 防止未授权而试图破坏与修改信息

1.2 信息安全特性

- 可用性：确保授权用户在需要时可以访问信息并使用相关信息资产
- 完整性：保护信息和信息的处理方法准确而完整
- 机密性：确保只有经过授权的人才能访问信息

1.3 网络安全的威胁

- 主动攻击

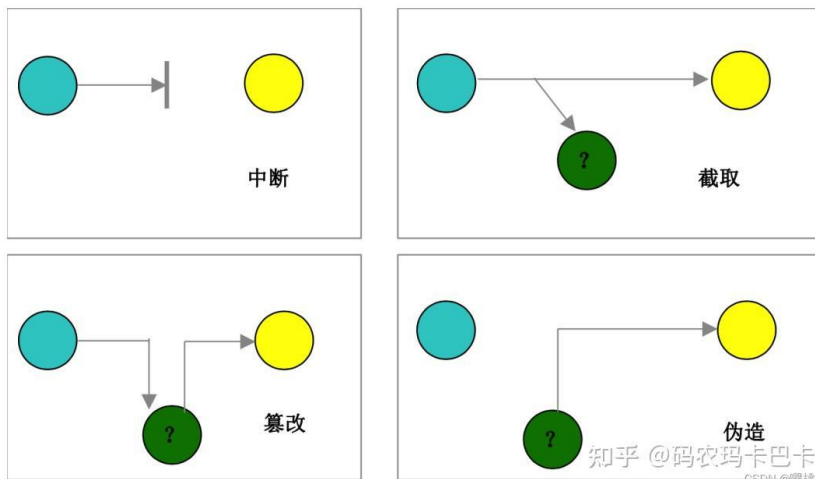
以各种方式有选择地破坏信息

添加、修改、删除、伪造、重放、乱序、冒充、病毒等

- 被动攻击

不干扰网络信息系统正常工作

侦听、截获、窃取、破译和业务流量分析及电磁泄露等



恶意攻击: [特洛伊木马](#)、[黑客攻击](#)、后门、计算机病毒、[拒绝服务攻击](#)、内外部泄密、蠕虫、逻辑炸弹、信息丢失篡改销毁

- **黑客攻击:** 黑客使用计算机作为攻击主体，发送请求，被攻击主机成为攻击对象的远程系统，进而被窃取信息。
- **特洛伊木马:** 特洛伊木马通过电子邮件或注入免费游戏一类的软件进行传播，当软件或电子邮件附件被执行后，特洛伊木马被激活。特洛伊木马释放他的有效负载，监视计算机活动，安装后门程序，或者向黑客传输信息。
- **拒绝服务攻击 DoS:** 指故意的攻击网络协议实现的缺陷或直接通过暴力手段耗尽被攻击对象的资源，目的是让目标计算机或网络无法提供正常的服务或资源访问，使目标系统停止响应甚至崩溃。这些服务资源包括网络带宽，文件系统空间容量，开放的进程或者允许的连接。

最常见的 DoS 攻击有对计算机网络的带宽攻击和连通性攻击。(1) 带宽攻击指以极大的通信量冲击网络，使得所有可用网络资源都被消耗殆尽，最后导致合法的用户请求无法通过。(2) 连通性攻击指用大量的连接请求冲击计算机，使得所有可用的操作系统资源都被消耗殆尽，最终计算机无法再处理合法用户的请求。

• 分布式拒绝服务攻击 DDoS:

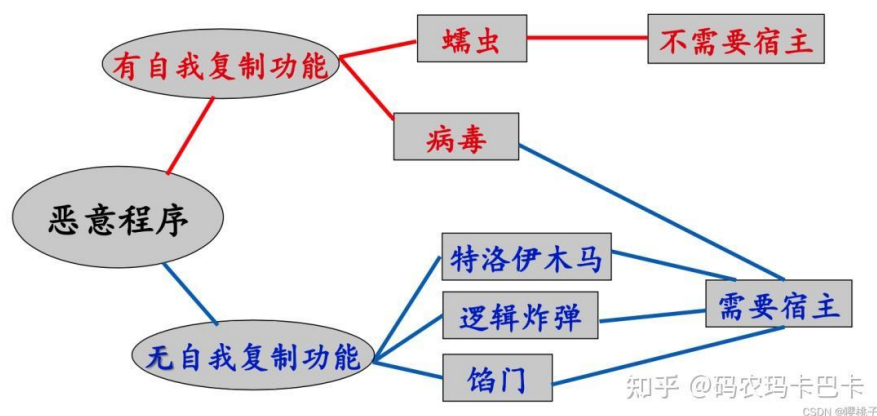
(1) 被攻击主机上有大量等待的 TCP 连接; (2) 网络中充斥着大量的无用的数据包; (3) 源地址为假,制造高流量无用数据，造成网络拥塞，使受害主机无法正常和外界通讯; (4) 利用受害主机提供的传输协议上的缺陷反复高速的发出特定的服务请求，使主机无法处理所有正常请求; (5) 严重时会造成系统死机。

- **病毒**：寄生在宿主文件中，将病毒代码嵌入到宿主文件中，针对本地程序或文件，宿主程序运行时被触发进行传染。防治的关键是将病毒代码从宿主文件中摘除。
- **蠕虫**：独立存在的程序个体，通过自身拷贝进行传染。针对网络上的其他计算机，通过系统漏洞进行传染。防治的关键是为系统打补丁。
- **漏洞**：指硬件、软件或策略上的缺陷，这种缺陷导致非法用户 未经授权而获得访问系统的权限或提高其访问权限。有了这种访问权限，非法用户就可以为所欲为，从而造成对网络安全的威胁。

区别于后门。后门：是软硬件制造者为了进行非授权访问而在程序中故意设置的万能访问口令，这些口令无论是被攻破，还是只掌握在制造者手中，都对使用者的系统安全构成严重的威胁。

漏洞与后门是不同的，漏洞是难以预知的，后门则是人为故意设置的。

- **TCP 劫持攻击**：A 尝试和 B 建立加密会话，黑客劫持通讯，假装是 B，然后和 A 交换密钥，然后假装是 A 和 B 建立会话。
- **IP 欺骗**：黑客更改原地址欺骗防火墙，防火墙允许数据包通过，将其误认为合法的通信，欺骗后的数据包进入内联网进行破坏。



1.4 网络安全的特征

• 保密性

网络信息不被泄露给非授权的用户、实体或过程。即信息只为授权用户使用。

保密性是在可靠性和可用性基础之上，保障网络信息安全的重要手段

常用的保密技术

- (1) 物理保密:利用各种物理方法，如限制、隔离、掩蔽、控制等措施，保护信息不被泄露(锁好柜、关好门、看好人)
- (2) 防窃听:使对手侦收不到有用的信息
- (3) 防辐射:防止有用信息以各种途径辐射出去,例:防窥。
- (4) 信息加密:在密钥的控制下，用加密算法对信息进行加密处理。即使对手得到了加密后的信息也会因为没有密钥而无法读懂有效信息

• 完整性

网络信息在存储或传输过程中保持不被偶然或蓄意地添加、删除、修改、伪造、乱序、重放等破坏和丢失的特性
完整性是一种面向信息的安全性，它要求保持信息的原样，即信息的正确生成、正确存储和正确传输

保障完整性的方法：

- (1) 良好的协议:通过各种安全协议可以有效地检测出被复制的信息、被删除的字段、失效的字段和被修改的字段
- (2) 密码校验和方法:它是抗篡改和传输失败的重要手段

(3) 数字签名:保障信息的真实性, 保证信息的不可否认性

(4) 公证:请求网络管理或中介机构证明信息的真实性

- 可靠性

(1) 系统能够在规定条件和时间内完成规定功能的特性, 是所有网络信息系统的运行和建设的基本目标。

(2) 通过抗毁性, 生存性与有效性进行衡量。

(3) 可靠性是在给定的时间间隔和给定条件下, 系统能正确执行其功能的概率。

(4) 提高可靠性需要强调减少系统中断(故障)的次数。

- 可用性

(1) 网络信息可被授权实体访问并按需求使用的特性。即网络信息服务在需要时, 允许授权用户或实体 使用的特性, 或者是网络部分受损或需要降级使 用时, 仍能为授权用户提供有效服务的特性

(2) 可用性是系统在执行任务的任意时刻能正常工作的概率, 一般用系统正常使用时间和整个工作时间之比来度量

(3) 提高可用性需要强调减少从灾难中恢复的时间

(4) 是产品可靠性、维修性和维修保障性的综合反映。

- 不可否认性

(1) 也称作不可抵赖性, 在网络信息系统的信息交互过程中, 确信参与者的真实同一性

(2) 所有参与者都不可能否认或抵赖曾经完成的操作和承诺

保证不可否认性的方法:

(1) 利用信息源证据可以防止发信方不真实地否认已发送信息, 利用递交接收证据可以防止收信方事后否认已经接收的信息

(2) 数字签名技术是解决不可否认性的手段之一

- 可控性

对信息的传播及内容具有控制能力

防止不良内容的传播

二、入侵方式

2.1 黑客

黑客(hacker):指技术上的行家或热衷于解决问题, 克服限制的人

骇客(cracker):是那些喜欢进入其他人系统的人

骇客和黑客之间最主要的不同是:黑客们创造新东西, 骇客们破坏东西。

2.1.1 入侵方法

(1) 物理侵入:侵入者绕过物理控制而获得对系统的访问。对主 有物理进入权限 (比如他们能使用键盘)。方法包括控制台特权一直到物理参与系统并且移走磁盘(在另外的机器读/写)。

(2) 系统侵入: 已经拥有在系统用户的较低权限。如果系统没有打最新的漏洞补丁, 就会给侵入者提供一个利用漏洞获得系统管理员权限的机会

(3) 远程侵入: 通过网络远程进入系统。侵入者从无特权开始这种侵入方式, 包括多种形式。如果在他和受害主机之间有防火墙存在, 侵入就复杂得多

2.1.2 系统的威胁

- 软件 bug

软件 bug 存在于服务器后台程序, 客户程序, 操作系统, 网络协议栈。

- 系统配置

(1) 缺省配置:许多系统交付给客户的时候采用的缺省的易用的配置

(2) 懒惰的系统管理员:惊人数量主机被配置成没有系统管理员口令

(3) 生成的漏洞:事实上所有的程序可能被配置成一个非安全的模式

(4) 信任的关系:侵入者常用“跳板”的方法利用信任关系攻击网络。一个互相信任主机的网络和他们最脆弱的环节一样安全。

- 口令解密

字典攻击:字典攻击可以利用重复的登陆或者收集加密的口令并且试图同加密后的字典中单词匹配

暴力破解(Brute Force Attacks): 同字典攻击类似, 侵入者可能尝试所有的字符组合方式

- 监听不安全的通信

(1) **共享媒体**: 传统的以太网中, 你只要在线上启动 [Sniffer](#) 就可以看到在一个网段的所有通信

(2) **服务器监听**: 在一个交换的网络里, 如果入侵者可以在一个服务器(特别是做路由器的)安装 sniffer 程序, 入侵者就可以使用得到的信息来攻击客户主机和信任主机。比如, 你可能不知道某个用户的口令, 通过在他登陆的时候监听 Telnet 会话, 就可以得到他的口令

(3) **远程监听**: 大量的主机可以远端网络监控, 且使用缺省的 community

• 设计的缺点

TCP/IP 协议缺点

系统设计缺点

2.2 IP 欺骗与防范

IP 欺骗就是伪造数据包源 IP 地址的攻击,

它基于两个前提:

- TCP/IP 网络在路由数据包时, 不对源 IP 地址进行判断— 可以伪造待发送数据包的源 IP 地址。目前黑客入侵攻击的重要手段之一。
- 主机之间有信任关系存在—基于 IP 地址认证, 不再需要用户账户和口令。

2.2.1 TCP 等 IP 欺骗基础知识

1. TCP 数据报首部标志域



URG:紧急数据标志, 指明数据流中已经放置紧急数据, 紧急指针有效;

ACK:确认标志, 用于对报文的确认;

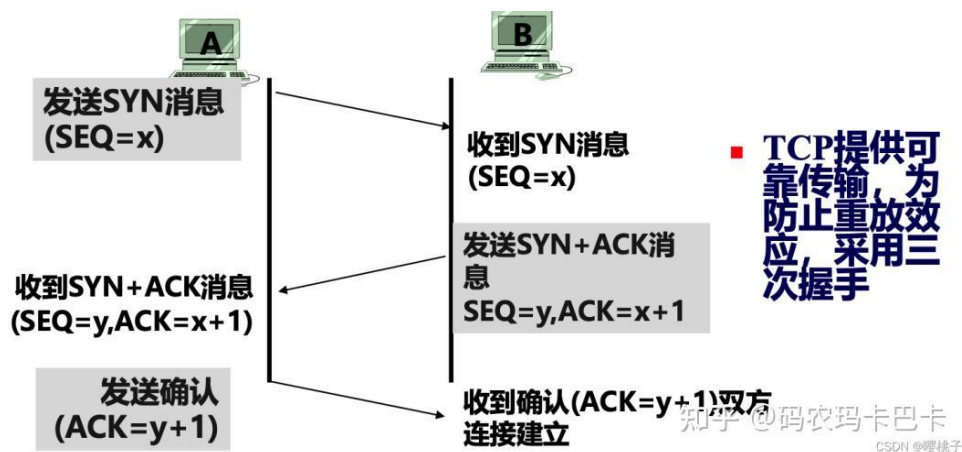
PSH:推标志, 通知接收端尽可能的将数据传递给应用层, 在 telnet 登陆时, 会使用到这个标志;

RST:复位标志, 用于复位 TCP 连接;

SYN:同步标志, 用于三次握手的建立, 提示接收 TCP 连接的服务端检查序号;

FIN:结束标志, 表示发送端已经没有数据再传输了, 希望释放连接, 但接收端仍然可以继续发送数据。

2. TCP 三次握手过程



1. A 发送带有 SYN 标志的数据段通知 B 需要建立 TCP 连接。并将 TCP 报头中的 sequence number 设置成自己本次连接的初始值 ISN。

2. B 回传给 A 一个带有 SYS+ACK 标志的数据段，并告诉 A 自己的 ISN，并确认 A 发送来的第一个数据段，将 acknowledge number 设置成 A 的 ISN+1。
3. A 确认收到的 B 的数据段，将 acknowledge number 设置成 B 的 ISN+1。

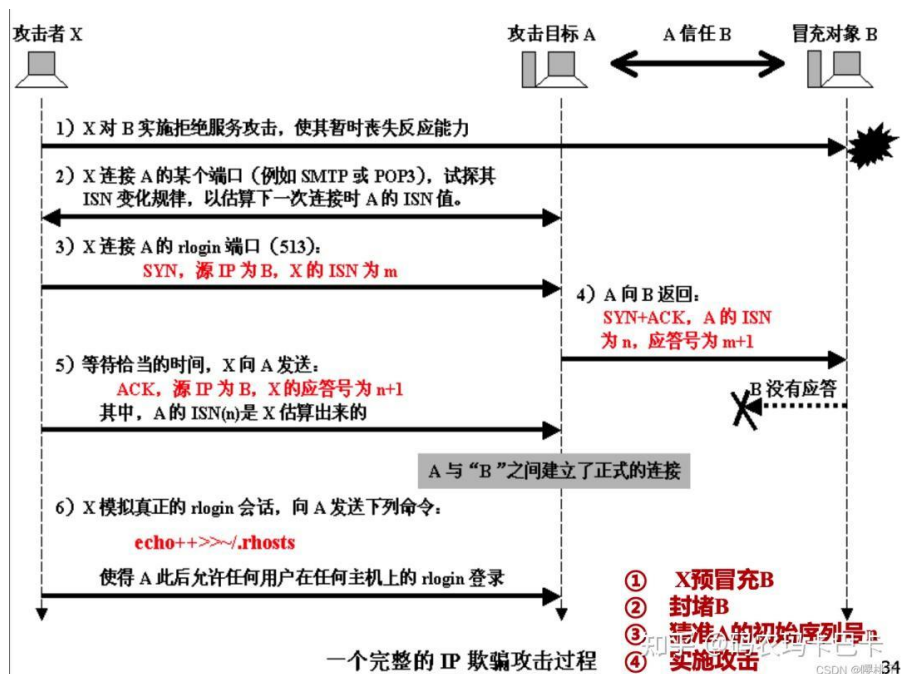
3. 信任与认证

- 1 基于口令的认证:如 SMTP(TCP 25)和远程登录 Telnet(TCP 23)，只通过帐号/口令认证用户;
- 2 基于 IP 地址的认证(即信任):登录主机的地址受到被登录服务器信任，则从该主机登录不要口令;如远程登录 rlogin(TCP 513)，首先是基于信任关系的认证，其次才进行口令认证。

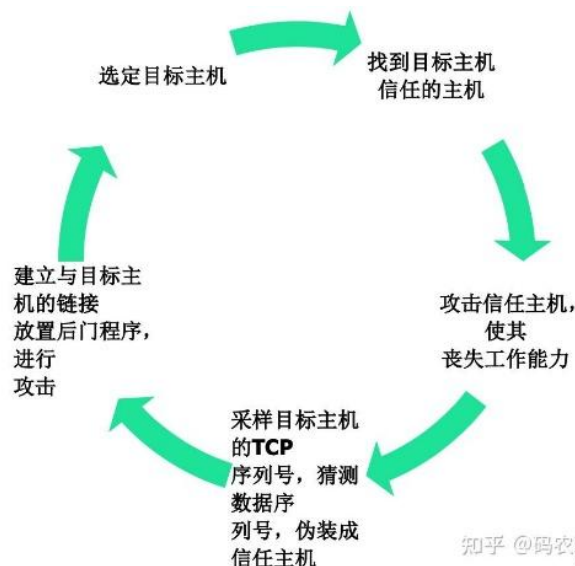
2.2.2 IP 欺骗可行的原因

1. 在 TCP/IP 协议组中，IP 协议是非面向连接，非可靠传输的协议，IP 数据包是进行松散发送的，并不是连续发送的，所以可以在源地址和目的地址中间放入满足要求的 IP 地址，(也就是说可以进行虚假 IP 地址的提供)
2. 在 TCP/IP 协议簇中，TCP 是面向连接，提供可靠传输。
3. 面向连接是两个主机首先必须建立连接，然后才能进行数据交换。
4. 可靠性是有数据包中的多位控制字来提供，其中有 两个是 SYN 和 ACK

2.2.3 IP 欺骗过程



IP 欺骗步骤



1.选定目标主机

利用端口扫描，网络监听工具看有哪些机器和目标主机进行 TCP/IP 连接

2.寻找目标主机信任的主机

选择好进攻的目标主机后，必须寻找到目标主机信任的主机

可以尝试显示目标主机的文件系统在哪里被 export，或者使用 rpcinfo 来分析有用信息

或者尝试目标主机的相邻 IP 地址，获取有价值信息

3.控制被信任的主机

黑客向被信任的主机的 TCPA 发送大量 SYN 请求，使得被信任主机的 TCP/IP 链接达到队列的最上限，从而无法响应目标主机的 SYN 请求

4.采样目标主机的 TCP 序列号，猜测数据包序列号，尝试建立连接

在此期间，黑客就有机会伪装成被信任主机的 IP 地址，将 SYN 请求返回给目标主机，

黑客利用网络监听和抓包软件，采样目标主机的 TCP 序列号，并猜测目标主机的数据包序列号，尝试建立与目标主机的基于地址验证的应用连接。

5.建立连接，种植后门

一旦与目标主机建立 TCP/IP 连接，黑客就会使用命令，通过目标主机的安全性较弱的端口，种植后门程序

6.进行远程控制和非法操作

后门种植成功后，黑客一般会断开与目标主机的连接，并且停止对被信任主机的攻击，全身而退。黑客推出后，找寻合理时机，对目标主机进行远程控制和非法操作。

2.2.4 IP 欺骗原理

序列号猜测

序列号猜测的重要性

- 攻击者 X 冒充受攻击目标 A 信任的对象 B，远程连接 A 的 rlogin 端口，如果能连接成功，不再需要口令就能登录 A。
- 因为 A 对 X 请求的响应包返回给 B，X 不可能知道其中 A 的序列号，要想在图中的第 5 步完成三次握手并连接成功，他必须“猜”到 A 的序列号(ISN)。

序列号猜测的过程

- X 首先连接 A 的 SMTP 端口(X 是 A 的合法的邮件用户，但不是它所信任的 rlogin 用户，因为邮件应用的安全级别相对不高)，试探其 ISN 变化规律，以估算下一次连接时 A 的 ISN 值。
 - X 必须马上按照图中 3—5 步的方法假冒 B 来与 A 建立 rlogin 连接。
- 1.X 必须立刻进行欺骗攻击，否则其他主机有可能与 A 建立了新的连接，X 所猜测的序列号就不准了。
- 2.当然就这样也不一定能一次猜测成功。

不同网络环境下的序列号猜测

- 1)若 X 和 A 及 B 在同一局域网中，从理论上说很容易实现 IP 欺骗攻击。因为攻击者 X 甚至于不用猜测 A 发送给 B 的数据包中包含的序列号——用嗅探技术即可。
- 2)若 X 来自于外网，要想猜测到 A 和 B 所在的局域网中传送的数据包中的序列号非常困难——理论可行。
- 3)美国头号电脑黑客米特尼克是第一个在广域网成功实现 IP 欺骗攻击的人。但当时的序列号相对现在非常容易猜测。

关于被冒充对象 B

- 1)X 首先必须对 B 进行 DoS 攻击，否则在图中第 4 步中 B 收到 A 发送来的它未请求过的请求应答包，将向 A 返回 RST 报文而终止连接，黑客不能冒充连接成功。
- 2)X 发送到 A 的 rlogin 端口的伪造数据包的源 IP 地址是“假冒”了 B 的 IP 地址。
- 3)为何 X 不能直接将自己的 IP 地址修改为 B 的 IP 地址来连接到 A 的 rlogin 端口？
1 IP 地址产生冲突；2 外网 X 不能这样修改。

2.2.5 IP 欺骗防范

使用较强壮的随机序列号生成器，要准确猜测 TCP 连接的 ISN 几乎不可能。

在边界路由器上进行源地址过滤，也就是说，对进入本网络的 IP 包，要检查其源 IP 地址，禁止外来的 却使用本地 IP 的数据包进入，这也是大多数路由器的缺省配置。

禁止 r-类型的服务，用 SSH(专为远程登录会话和其他网络服务提供安全性的协议,传输的数据均加密)代替 rlogin

这样的不安全的网络服务。

在通信时要求加密传输和验证。

分割序列号空间。Bellovin 提出一种弥补 TCP 序列号随机性不足的方法，就是分割序列号空间，每一个连接都将有自己独立的序列号空间。连接之间序列号没有明显的关联。

2.3 Sniffer 探测与防范

2.3.1 Sniffer 原理

1. 广播类网络上，可以将某一网络适配器(NIC)设为接收相应广播域上传的所有帧
2. sniffer 属第二层次(数据链路层)的攻击。通常是攻击者已经进入了 目标系统
3. 如果 sniffer 运行在路由器，或有路由器功能的主机上，则可同时监视多个广播域，危害更大
4. 通常，sniffer 程序只需看到一个数据包的前 200-300 个字节的数据， 就能发现用户名和口令等信息

2.3.2 Sniffer 防范

- 设法保证系统不被入侵

Sniffer 往往是攻击者在侵入系统后使用

- 加密传输

传输前加密，使收集的信息无法解读

- 采用安全拓扑结构

采用交换技术，分割广播域。

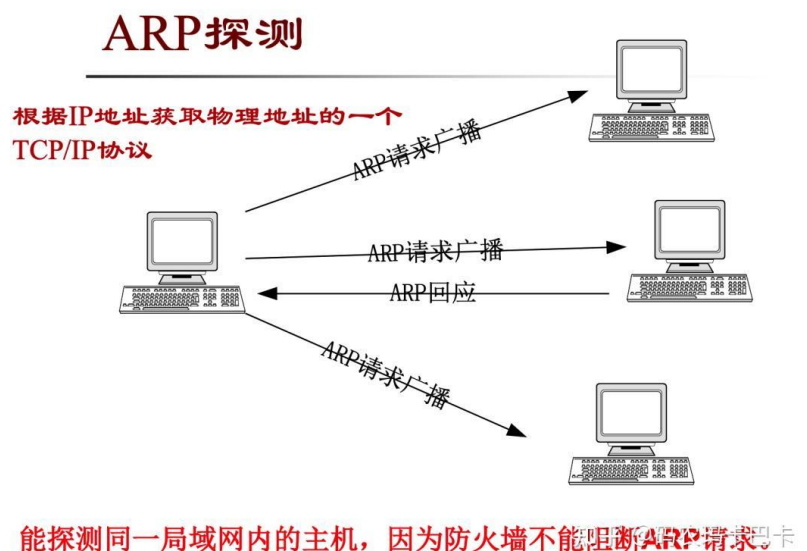
管理员应使各计算机之间的信任关系最小，如 lan 要和 internet 相 连，仅有 firewall 是不行的，要考虑一旦入侵成功他能得到什么， 保证一旦出现 sniffer 他只对最小范围有效

现代网络常常采用交换机作为网络连接设备枢纽

交换机不会让网络中每一台主机侦听到其他主机的通讯，因此 Sniffer 技术在这时必须结合网络端口镜像技术进行配合。

而衍生的安全技术则通过 ARP 欺骗来变相达到交换网络中的侦听。

- 网络端口镜像技术：在交换机或路由器上， 将一个或多个源端口的数据流量转发到某一个指定端口来实现对网络的监听
- ARP 欺骗: ARP 欺骗的运作原理是由攻击者发送假的 ARP 数据包到网上，尤其是送到网关上。其目的是要让送至特定的 IP 地址的流量被错误送到攻击者所取代的地方。



回顾知识：交换机、路由器、集线器

- 路由器(Router): 是连接因特网中各局域网、广域网的设备。在路由器中记录着路由表，它会根据信道的情况自动选择和设定路由，以最佳路径，按前后顺序发送信号。发生在网络层。提供了防火墙的服务，只转发特定地址的数据包，不传送不支持路由协议的数据包传送和求知目标网络数据包的传送，从而可以防止广播风暴。

- 交换机(Switch): 是一种用于电(光)信号转发的网络设备。它可以为接入交换机的任意两个网络节点提供独享的电信号通路, 把传输的信息送到符合要求的相应路由上。发生在数据链路层。
- 集线器(Hub): 是指将多条以太网双绞线或光纤集合连接在同一段物理介质下的设备。发生在物理层。

2.4 端口扫描技术

2.4.1 原理

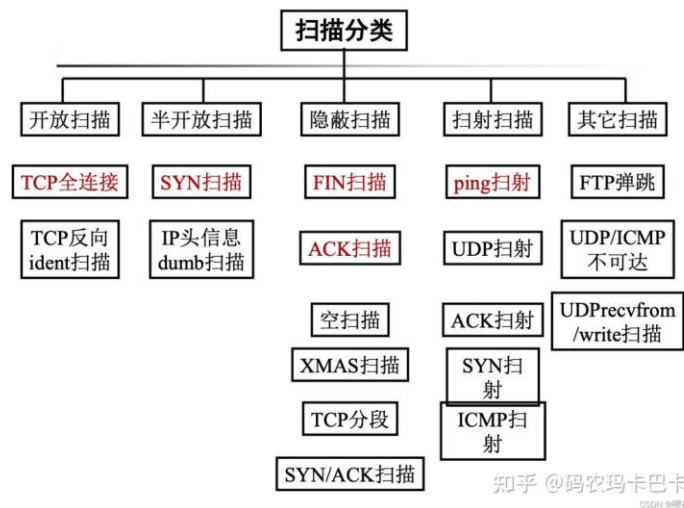
端口扫描是指某些别有用心的人发送一组端口扫描消息, 试图以此侵入某台计算机, 并了解其提供的计算机网络服务类型(这些网络服务均与端口号相关);

扫描器(工作原理):

自动检测远端或本机安全性弱点的程序, 用户可不留痕迹的发现远端机器各端口的分配及运行的服务及软件版本功能

- 发现一个主机或网络;
- 发现该主机运行何种服务;
- 测试这些服务发现漏洞

2.4.2 分类



常见的端口扫描类型

- TCPconnect(): 入侵者无须任何权限, 速度快, 但是其易被发现, 也易被过滤;
- TCPSYN: 扫描器发送 syn 数据包, 如果返回 ack/syn 同时需要再发送 RST 关闭连接过程, 表示端口处监听状态;如果返回 RST, 则不在侦听, 不会留下入侵记录, 但需要有 root 权限才能建立自己的 syn 数据包
- TCPFIN: 一般防火墙或过滤器会过掉 syn 包, 但 FIN 可以没有麻烦的通过, 于是可能存在关闭的端口会用 RST 来响应 FIN,而打开的端口 则不会响应, 但有的系统不管打开与否都响应回复 RST 包

2.4.3 ping 命令

Ping 的原理

通过向目标主机传送一个小数据包, 目标主机接收并将该包返送回来, 如果返回的数据包和发送的数据包一致, 则 Ping 命令成功。根据返回的信息, 可以推断 TCP/IP 参数是否设置正确, 以及运行是否正常、网络是否通畅等。

作用和特点

- 用来判断目标是否活动;
- 最常用、最简单的探测手段;
- Ping 程序一般是直接实现在系统内核中的, 而不是一个用户进程

Ping 命令可以进行以下操作 :

1. 通过将 ICMP(Internet 控制消息协议)回显数据包发 送到计算机并侦听回显回复数据包来验证与一台或多台远程计算机的连接。

2. 每个发送的数据包最多等待一秒。
3. 打印已传输和接收的数据包数。

2.5 特洛伊木马

2.5.1 木马与病毒的区别

• 载体

- 一般情况下，病毒是依据其能够进行自我复制即传染性的特点而定义的
- 木马主要是根据它的有效载体，或者是其功能来定义的，更多情况下是根据其意图来定义的

• 自我复制和传播

- 木马一般不进行自我复制，但具有寄生性，如捆绑在合法程序中得到安装、启动木马的权限，DLL 木马甚至采用动态嵌入技术寄生在合法程序的进程中
- 木马一般不具有普通病毒所具有的自我繁殖、主动感染传播等特性，但我们习惯上将其纳入广义病毒，也就是说，木马也是广义病毒的一个子类

• 意图

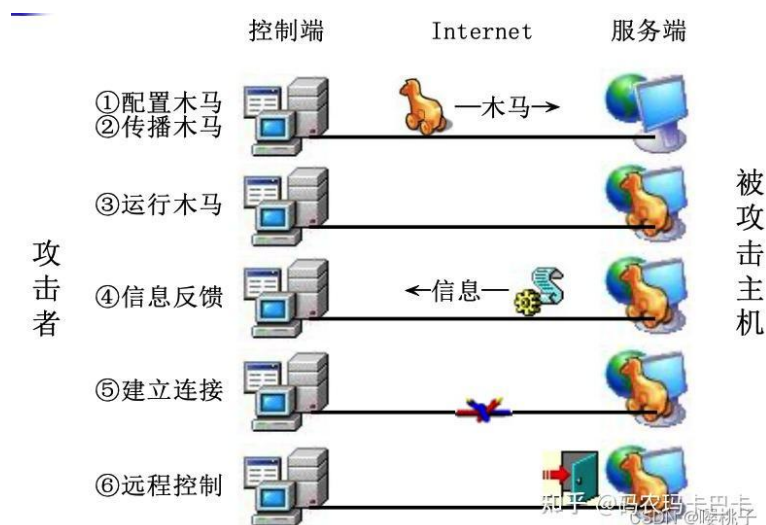
- 木马的最终意图是窃取信息、实施远程监控
- 木马与合法远程控制软件(如 pcAnyWhere)的主要区别在于是否 是否具有隐蔽性、是否具有非授权性

2.5.2 木马的组成

木马系统软件一般由木马配置程序、控制程序和木马程序(服务器程序) 三部分组成。

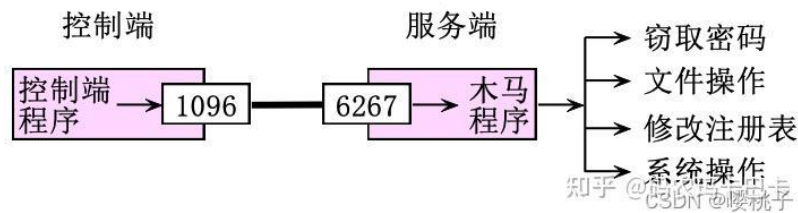


2.5.3 木马攻击过程



木马通道与远程控制

- 木马连接建立后，控制端端口和服务端木马端口之间将会出现一条通道；
- 控制端上的控制端程序可借助这条通道与服务端上的木马程序取得联系，并通过木马程序对服务端进行远程控制，实现的 远程控制就如同本地操作



2.5.4 传播方式

• 捆绑欺骗

- 把木马服务端和某个游戏/软件捆绑成一个文件
- 通过即时通讯工具、邮件、下载工具等渠道发送出去

• 钓鱼欺骗(Phishing)

- 构造一个链接或者一个网页
- 利用社会工程学欺骗方法
- 欺骗用户输入某些个人，隐私信息，然后窃取个人隐私

• 漏洞攻击

- 利用操作系统和应用软件的漏洞进行的攻击

• 网页挂马

- 网页挂马就是攻击者通过在正常的页面中(通常是网站的主页)插入一段代码。
- 浏览者在打开该页面的时候，这段代码被执行，然后下载并运行某木马的服务器端程序，进而控制浏览者的主机

三、防火墙技术

3.1 防火墙基础

3.1.1 基本概念

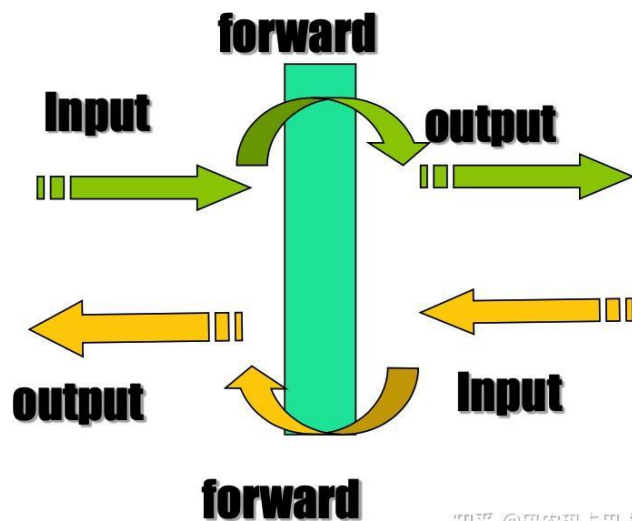
防火墙：过滤！

实现一个机构的安全策略

创建一个阻塞点

记录 internet 活动

限制网络暴露

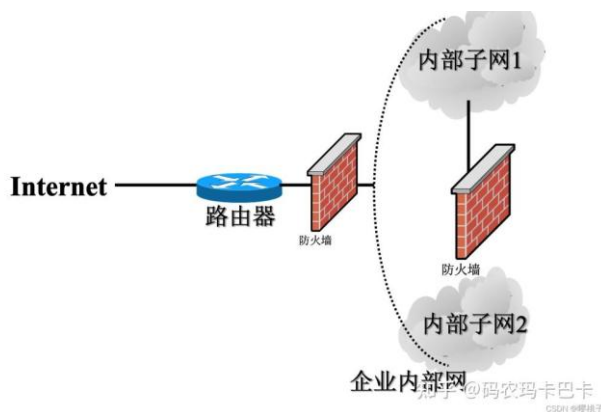


什么是防火墙？

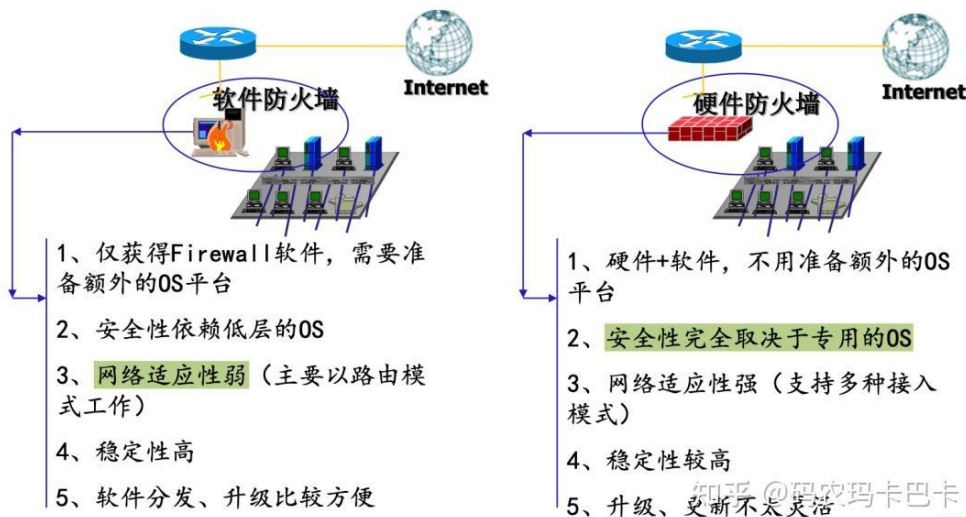
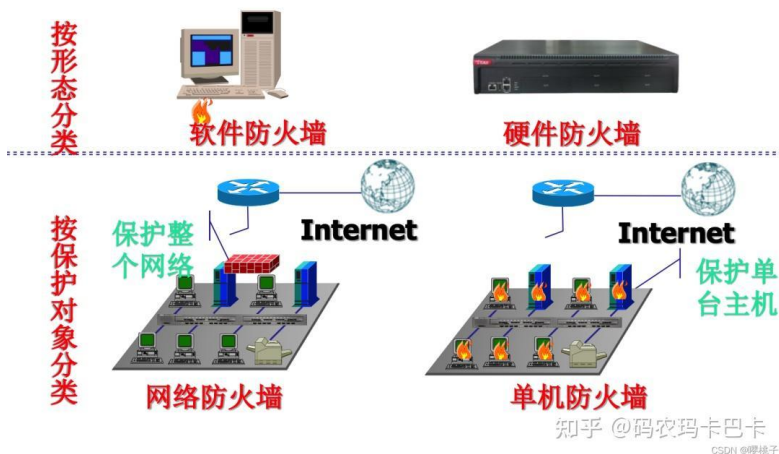
- 防火墙是设置在用户网络和外界之间的一道屏障，防止不可预料的、潜在的破坏侵入用户网络；
- 防火墙在开放和封闭的界面上构造一个保护层，属于内部范围的业务，依照协议在授权许可下进行；外部对内部网络的访问受到防火墙的限制

防火墙功能

- 过滤进出网络的数据
- 管理进出网络的访问行为
- 封堵某些禁止的访问行为
- 记录通过防火墙的信息内容和活动
- 对网络攻击进行检测和告警



防火墙分类



3.1.2 访问控制机制

访问控制机制的演变

- 1、路由器—>ACL 访问控制列表
- 2、包过滤防火墙—>根据 IP 五元组判断能否通过
- 3、状态监测防火墙—>根据应用判断能否通过
- 4、应用代理防火墙—>根据应用判断能否通过
- 5、多检测机制防火墙—>根据多个 IP 包判断整体应用后判断能否通过
- 6、多功能集成网关(下一代防火墙)—>嵌入多种防护功能，经过多层过滤后判断能否通过

1. 包过滤防火墙

数据包过滤(Packet Filtering)技术在网络层对数据包进行选择，选择的依据是系统内设置的过滤逻辑，即访问控制表(Access Control List, ACL)

- 包过滤防火墙分为静态包过滤、动态包过滤防火墙
- 包检查器并不是检查数据包的所有内容，只检查报头(IP、TCP 头部)



优点

◆逻辑简单 ◆有较强的透明性 ◆网络性能的影响较小 ◆开销较小，设备便宜

缺点

- ◆无法对数据包的内容进行过滤审核
- ◆在传输层或则是网络层上检测数据，不能在更高层检测数据，比如能禁止和通过一个向内的 HTTP 请求，但不能判断这个请求是非法的还是合法的。
- ◆防止欺骗攻击很难，特别是容易受到 IP 欺骗攻击(允许来自网络外部的流量，包过滤防火墙只能检测数据包中的源 IP，无法确定是否是真正的源地址)
- ◆所有可能用到的端口(尤其是>1024 的端口)都必需放开,增加了被攻击的可能性
- ◆在复杂的网络中很难管理
- ◆通常来说包过滤技术是防火墙技术中最低的。

2. 状态检测防火墙

状态检测防火墙由动态包过滤防火墙演变而来，工作在传输层，使用各种状态表(state tables)来追踪活跃的 TCP 会话，它能够根据连接状态信息动态地建立和维持一个连接状态表，并且把这个连接状态表用于后续报文的处理。



状态检测技术一般的检查点有：

- 检查数据包是否是一个已经建立并且正在使用的通信流的一部分。
- 如果数据包和连接表的各项都不匹配，那么防火墙就会检测数据包 是否与它所配置的规则集相匹配。
- 在检测完毕后，防火墙会根据路由转发数据包，并且会在连接表中 为此次对话创建或者更新一个连接项
- 防火墙通常对 TCP 包中被设置的 FIN 位进行检测、通过会话超时设置决定何时从连接表中删除某连接项。

优点

- ◆更高的安全性
- ◆高效性
- ◆应用范围广

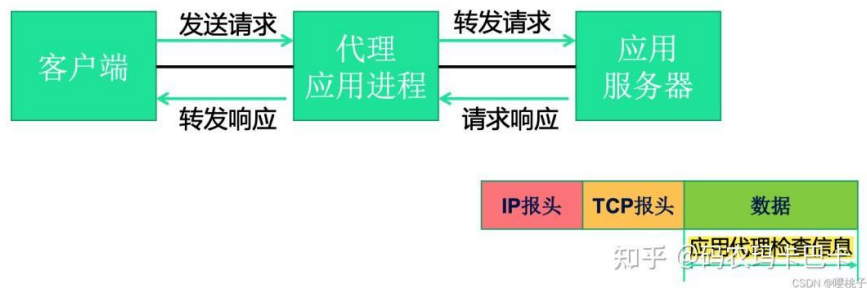
缺点

- ◆不能对应用层数据进行控制
- ◆不能产生高层日志
- ◆配置复杂

3. 应用代理防火墙

应用代理(Application Proxy)也称为应用层网关(Application Gateway)

- 工作在应用层，其核心是代理进程
- 每一种应用对应一个代理进程，实现监视和控制应用层通信流
- 自适应代理防火墙:在每个连接通信的开始仍然需要在应用层接受检测，而后面的包可以经过安全规则由自适应代理程序自动的选择是使用包过滤还是代理



优点

- ◆可以检查应用层、传输层和网络层的协议特征，对数据包的检测能力比较强
- ◆代理完全控制会话，可以提供很详细的日志和安全审计功能
- ◆可以隐藏内部网的 IP 地址，保护内部主机免受外部主机的进攻
- ◆可以集成认证机制

缺点

- ◆最大缺点是要求用户改变自己的行为，或者在访问代理服务的 每个系统上安装特殊的软件
- ◆分析困难，实现困难，每一种应用服务必须设计一个代理软件模块进行安全控制，并 且应用升级时，一半代理服务程序也要升级
- ◆影响用户网络速度(命令解释)
- ◆不能防止 SYN 攻击

4. 复合型防火墙

复合型防火墙是指综合了状态检测与应用代理的新一代的防火墙

- 对整个报文进行访问控制和处理，具体检测内容由策略决定，
- 如果策略是包过滤策略，则对 TCP、IP 报头进行检测，
- 如果策略是应用代理策略，则对用户数据进行检测



优点

- ◆可以检查整个数据包的内容
- ◆根据需要建立连接状态表
- ◆网络层保护强
- ◆应用层控制细

缺点

- ◆会话控制较弱

5. 核检测防火墙

对于简单包过滤防火墙、状态检测包过滤防火墙和应用代理防火墙，他们只是检查单个报文，所以只检查其中的一个报文，但是他们都不能把这些报文组合起来，形成一个会话 来进行处理。

对于核检测防火墙，它可以将不同报文，在防火墙内部， 模拟成应用层客户端或服务器端，对整个报文进行重组，合成一个会话来进行理解， 进行访问控制。

可以提供更细的访问控制，同时能生产访问日志。可以看到，它的上下报文是相关的，它具备包过滤和应用代理防火墙的全部特点，还增加了对会话的保护能力。



优点

- ◆网络层保护强
- ◆应用层保护强
- ◆会话层保护强
- ◆前后报文有联系，可以关联进行出来

缺点

- ◆不能防病毒传播
- ◆不能防止一些未知的入侵或攻击

小结

- **包过滤防火墙**: 包过滤防火墙不检查数据区，包过滤防火墙不建立连接状态表，前后报文无关，应用层控制很弱。
- **应用代理防火墙**: 不检查 IP、TCP 报头，不建立连接状态表，网络层保护比较弱，影响用户的网速。
- **状态检测防火墙**: 不检查数据区，建立连接状态表，前后报文相关，应用层控制很弱。
- **复合型防火墙**: 可以检查整个数据包内容，根据需要建立连接状态表，网络层保护强，应用层控制细，会话控制较弱
- **核检测防火墙**: 可以检查整个数据包内容，网络层保护强，应用层保护强，前后报文有联系。

3.2 防火墙设计原则及优缺点

3.2.1 设计原则

- **过滤不安全服务的原则**
- 防火墙应封锁所有信息流，然后对希望提供的安全服务逐项开放
- 这是一种非常有效实用的方法，可以造成一种十分安全的环境，因为只有经过仔细挑选的服务才能允许用户使用
 - **屏蔽非法用户的原则**
- 防火墙可先允许所有的用户和站点对内部网络的访问，然后网络管理员按照 IP 地址对未授权的用户或不信任的站点进行逐项屏蔽
- 这种方法构成了一种更为灵活的应用环境，网络管理员可以针对不同的服务面向不同的用户开放，也就是能自由地设置各个用户的不同访问权限

3.2.2 优缺点

优点:

- 允许管理员定义一个中心扼制点防止非法用户进入内部网络

- 保护网络中脆弱的服务
- 用户可方便的监视网络的安全并产生报警
- 集中安全性
- 增强保密性
- 是审计和记录网络流量的一个最佳地方

缺点:

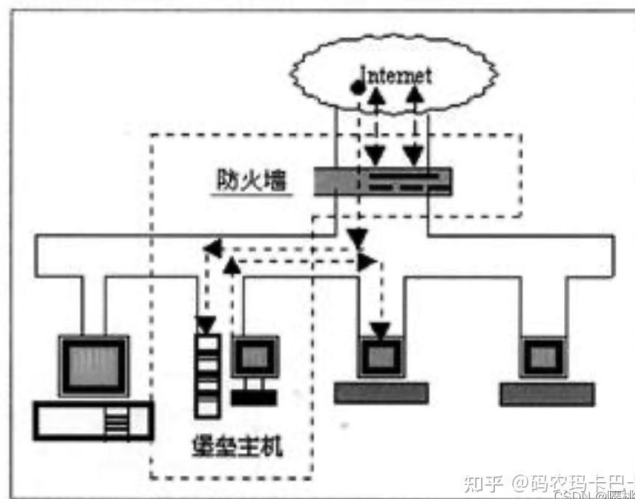
- 限制有用的服务
- 不能有效防止内部的攻击
- Internet 防火墙不能防止通过防火墙以外的攻击
- 不能完全防止传送已感染病毒的文件和软件
- 无法防范数据驱动型攻击
- 不能防备新的网络安全问题

3.3 防火墙体系结构

• 屏蔽主机网关 Screened Host Gateway

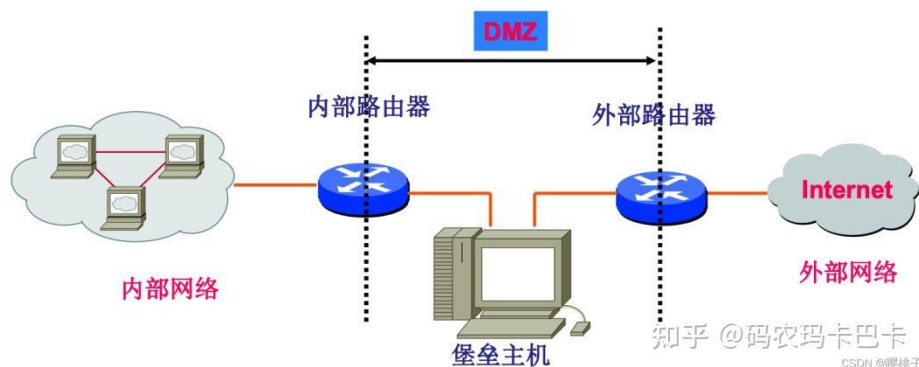
包过滤路由器只放行到堡垒主机的数据包

- 一个分组过滤路由器 连接外部网络
- 一个堡垒主机安装在 内部网络上;
- 通常在路由器上设立过滤规则，并使这个 堡垒主机成为从外部网络唯一可直接到达 的主机，这确保了内部网络不受未被授权 的外部用户的攻击



• 屏蔽子网 Screened Subnet Firewall

- 在内部网络和外部网络之间增加一个子网
- 屏蔽子网区域称为边界网络 Perimeter Network，也称为非军事区 DMZ(De-Militarized Zone)



入侵者攻击内部网络至少要突破两个路由器:

- 内部路由器

- 负责管理 DMZ 到内部网
- 仅接收来自堡垒主机的数据包
- 完成防火墙的大部分工作

- 外部路由器

- 防范通常的外部攻击网的访问
- 管理 Internet 到 DMZ 的访问
- 只允许外部系统访问堡垒主机

- 堡垒主机

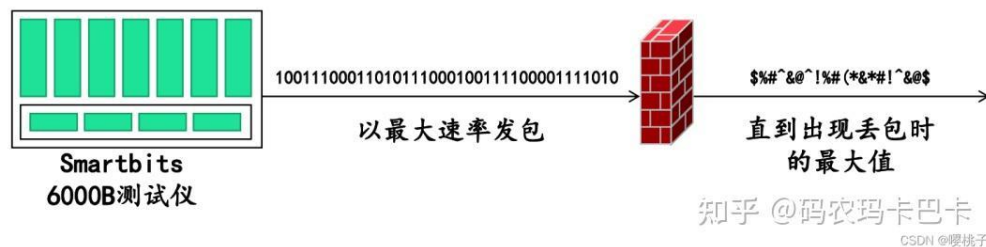
- 安全防护、运行各种代理服务

3.4 硬件防火墙的性能指标

1. 吞吐量

1、定义:在不丢包的情况下能够达到的最大速率

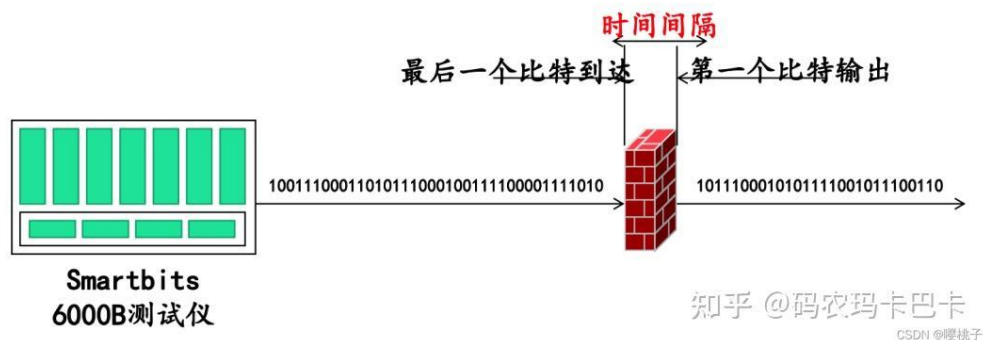
2、衡量标准:吞吐量作为衡量防火墙性能的重要指标之一，吞吐量小就会造成网络新的瓶颈，以致影响到整个网络的性能



2. 延时

1、定义:入口输入帧最后一个比特到达至出口处 输出帧的第一个比特 输出所用的时间间隔

2、衡量标准:防火墙的延时能够体现出它处理数据的速度



3. 丢包率

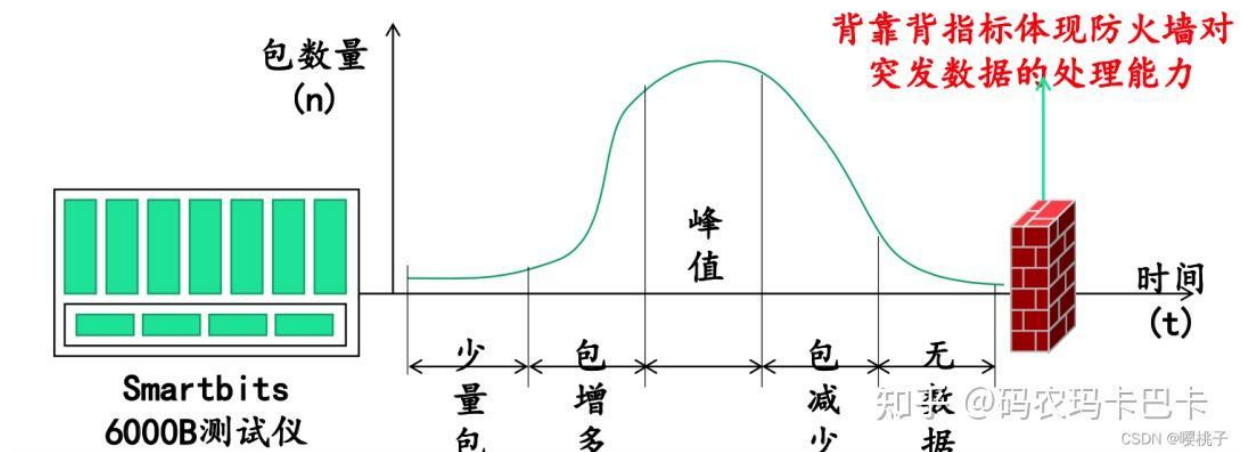
1、定义:在连续负载的情况下，防火墙设备由于资源不足应转发但却未转发的帧百分比

2、衡量标准:防火墙的丢包率对其稳定性、可靠性有很大的影响



4. 背靠背

- 1、定义:从空闲状态开始,以达到传输介质最小合法间隔极限的传输速率发送相当数量的固定长度的帧,当出现第一个帧丢失时,发送的帧数
- 2、衡量标准:背对背包的测试结果能体现出被测防火墙的缓冲容量,网络上经常有一些应用会产生大量的突发数据包(例如:NFS、备份、路由更新等),而且这样的数据包的丢失可能会产生更多的数据包,强大的缓冲能力可以减小这种突发情况对网络造成的影响

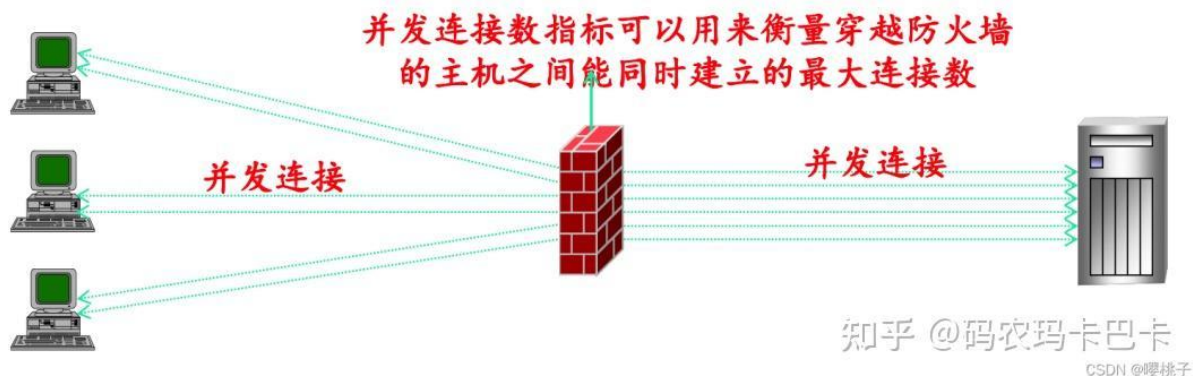


5. 最大并发连接数

最大并发连接数:

指穿越防火墙的主机之间与防火墙之间能同时建立的最大连接数

- 衡量标准:并发连接数的测试主要用来测试被测防火墙建立和维持 TCP 连接的性能,同时也能通过并发连接数的大小体现被测防火墙对来自于客户端的 TCP 连接请求响应的能力



6. 每秒新建连接数

每秒新建连接数则指防火墙由开始建立连接直到达到最大连接数的速率指标,也是防火墙的性能指标之一

3.4 分布式防火墙

边界防火墙的固有欠缺：

1. 结构上受限制：企业网物理边界日趋模糊
2. 内部不够安全：80%的攻击和越权访问来自于内部
3. 效率不高：边界防火墙把检查机制集中在网络边界的单点，造成了网络访问的瓶颈问题(大容量、高性能、可扩展、安全策略的复杂性)
4. 单点故障：边界防火墙本身也存在着单点故障危险，一旦出现问题或被攻克，整个内部网络将会完全暴露在外部攻击者面前

3.4.1 定义

1. 从狭义来讲，分布式防火墙产品是指那些驻留在网络主机中，如服务器或桌面机，并对主机系统自身提供安全防护的软件产品
2. 从广义来讲，分布式防火墙是一种新的防火墙体系结构。

■ 它们包含如下产品:网络防火墙、主机防火墙、中心管理等

1、网络防火墙

用于内部网与外部网之间(即传统的边界防火墙)和内部网子网之间的防护产品

2、主机防火墙

对于网络中的服务器和桌面机进行防护，这些主机的物理位置可能在内部网中，也可能在内部网外，如托管服务器或移动办公的便携机

3、中心管理

中心管理是分布式防火墙系统的核心和重要特征之一

■ 总体安全策略的策划、管理、分发及日志的汇总，解决了由分布技术而带来的管理问题。

■ 边界防火墙只是网络中的单一设备，管理是局部的。对分布式防火墙来说，每个防火墙作为安全监测机制可以根据安全性的不同要求布置在网络中的任何需要的位置上，但总体安全策略又是统一策划和管理的，安全策略的分发及日志的汇总都是中心管理应具备的功能。

优点

1、增加系统安全性

- (1)增加了针对主机的入侵监测和防护功能;
- (2)加强了对来自内部攻击的防范;
- (3)可以实施全方位的安全策略;
- (4)提供了多层次立体的防范体系。

2、保证系统性能

消除了结构性瓶颈问题，提高了系统性能。

3、系统的可扩展性

随系统扩充提供了安全防护无限扩充的能力。

四、密码学基础

4.1 定义

密码技术通过信息的变换或编码，将机密消息变换成乱码型文字，使非指定的接收者不能由其截获的乱码中得到任何有意义的信息，并且不能伪造任何乱码型的信息

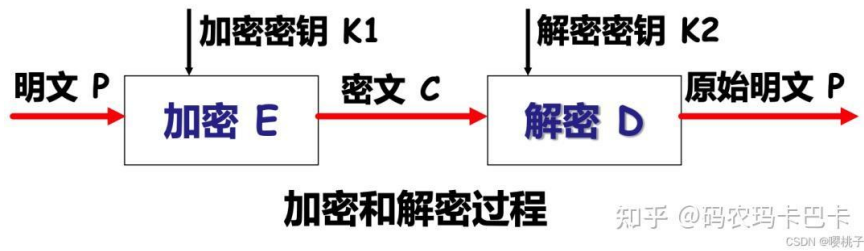
研究密码技术的学科称为密码学(cryptology)，它包含两个分支：

- 密码编码学(cryptography) - 对信息进行编码实现信息隐蔽
- 密码分析学(cryptanalysis) - 研究分析如何破译密码

术语：

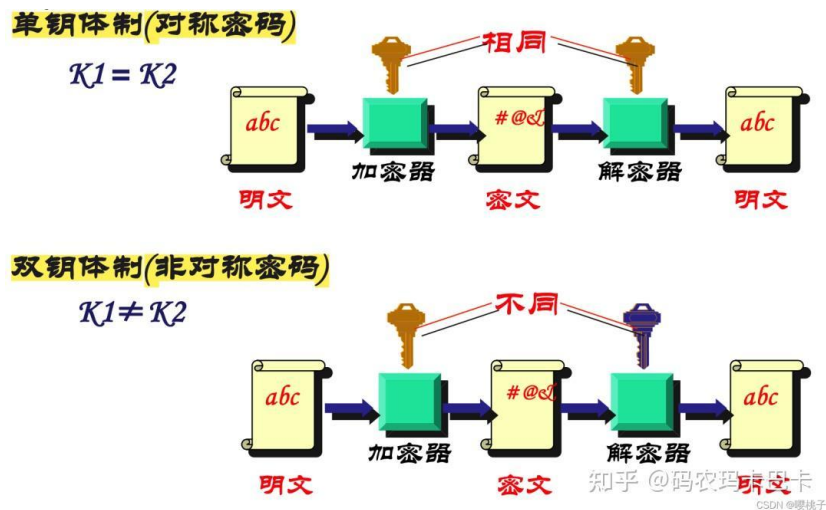
- 未加密的消息(Message)被称为明文(PlainText);(它可能是比特流，也可能是文本文件、位图、数字化的语音流或数字化的视频图像);
- 被加密的消息称为密文(Cipher);
- 用某种方法伪装消息以隐藏它的内容的过程称为加密(Encryption);
- 把密文转变为明文的过程称为解密(Decryption);
- 密钥:参与变换的参数,用 K(Key)表示;
- 加密算法:对明文进行加密时采用的一组规则;

- 解密算法:对密文解密时采用的一组规则;
- 使消息保密的技术和科学叫做密码编码学(Cryptography);
- 破译密文的科学和技术是密码分析学(Cryptanalysis);



4.2 对称和非对称加密

- 对称密钥算法:K1 与 K2 相同
- 非对称密钥算法:K1 和 K2 可以相同, 也可以不同



对比

单钥密码体制中, 收发双方使用同一密钥, 系统的保密性主要取决于密钥的安全性。系统的密钥管理、传输和分配是一个重要且十分复杂的问题。

单钥的优点是: 保密强度高, 运算速度快, 缺点是密钥数目大, 密钥分配困难, 无法实现不可否认服务。

公钥密码体制中, 加密密钥 K 是公开的, 解密密钥 K 必须保密。公钥体制的密钥产生、分配和管理相对简单, 尤适用于计算机网络系统中。

公钥体制的特点: 实现信息公开加密, 实现不可否认服务, 但缺点是加解密运算复杂, 速度较慢。

两类密码攻击法

1. 穷举法
2. 分析破译法

常见密码分析攻击

- a. 唯密文攻击
- b. 已知明文攻击
- c. 选择明文攻击
- d. 自适应选择明文攻击
- e. 选择密文攻击
 - 唯密文攻击

密码分析者有一些用同一加密算法加密的消息的密文，他们的任务是恢复尽可能多的明文，或者最好是能推算出加密消息的密钥，以便使用密钥解出其他被加密的消息。

• 已知明文攻击

密码分析者得到一些消息的密文和相应的明文后，用加密信息推出用来加密的密钥或导出一个算法，此算法可以对用同一密钥加密的任何新的消息进行解密

• 选择明文攻击

■ 如果分析者能够用某种方式进入源系统，并向系统中插入分析者自己选定的明文

■ 这时，密码分析者能选择特定的明文块去加密，并比较明文和对应的密文信息，从中可以发现更多与密钥有关的信息。这往往比已知明文攻击更有效。此时，分析者的任务是推出用来加密消息的密钥或导出一个算法，该算法可以对用同一密钥加密的任何新的消息进行解密。

• 自适应选择明文攻击

■ 这是选择明文攻击的特殊情况。

■ 密码分析者不仅能选择被加密的明文，而且也能基于以前加密的结果修正这个选择。

■ 在选择明文攻击中，密码分析者可以选择一大块待加密的明文。而在自适应选择密文攻击中，密码分析者可选取较小的明文块，然后再基于第一块的结果选择另一明文块，以此类推

• 选择密文攻击

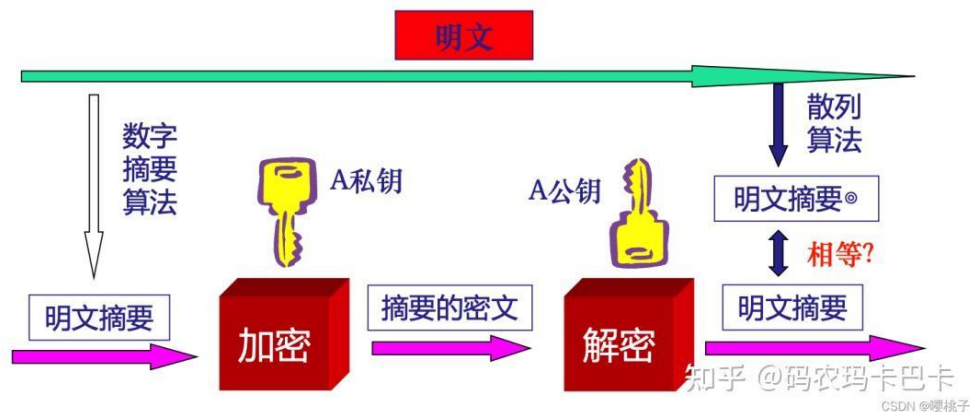
■ 密码分析者能选择不同的被加密的密文，并可得到相应的明文。密码分析者的任务是推出密钥。例如，用一定的手段在通信过程中伪造消息替换真实消息，然后窃取通信另一方获得并解密的结果，有可能正好发现随手伪造的密文解密结果是有意义的

已知: C_1 , $P_1 = D_k(C_1)$, C_2 , $P_2 = D_k(C_2)$, ..., C_i , $P_i = D_k(C_i)$, 推导出: K

■ 用于公开密钥体制

■ 选择密文攻击有时也可有效地用于对称算法(有时选择明文攻击和选择密文攻击一起称作选择文本攻击)

数字签名



4.3 加密算法

• 经典密码

• 替代密码: 单表替换密码 (凯撒密码)、同音替代密码、多字母组替密码、多表替换密码 (Vigenere)

• 置换密码: 完全倒置法、分组倒置法、列换位法、矩阵换位法、双换位密码

• 对称加密算法: DES、AES

• 非对称公钥算法: RSA、背包密码、McEliece 密码、Rabin、椭圆曲线、ElGamal D_H

版权声明：本文为 CSDN 博主「樱桃子」的原创文章，遵循 CC 4.0 BY-SA 版权协议，转载请附上原文出处链接及本声明。(侵权)

原文链接：<https://blog.csdn.net/CherryChenieth/article/details/124109382>

编辑于 2022-07-18 16:57